

January 2026 CSE 406: Cyber Security Sessional

Online 2: Ethical Hacking

Section: A2

Time: 40 minutes

Ethical-use warning

This is an intentionally vulnerable, isolated teaching environment. Use the techniques in this assignment only against the supplied local containers. Never test an application, account, or network without explicit authorization. The same actions against a real service may be unethical and illegal.

Objective

You have access to two campus applications: the **Loan Management Portal** and **Student Chat**. Acting only as the designated attacker account, fully compromise the pair as follows:

Discover the structure of the Loan Management database and extract every student's current loan amount. Then, through the same vulnerable login input, persist a browser payload in your own record so that logging in normally automatically posts a message in Student Chat containing a convincing reward link. Finally, demonstrate that a victim who is logged into the Loan Management Portal and clicks that reward link has their own loan amount increased by exactly \$1000, without ever submitting a victim identifier yourself.

Environment Setup

The Moodle archive contains `A2-images.tar`, `compose.yaml`, and this specification. Internet access is not required after download. From the directory containing those files, run:

```
seed@ubuntu:~$  
  
docker load --input A2-images.tar  
docker compose up -d  
docker compose ps
```

Wait until all three services are running. Open:

- Loan Management Portal: `http://localhost:7000`
- Student Chat: `http://localhost:7001`

To reset every database change, session, and chat message and return to the original seeded state:

```
seed@ubuntu:~$  
  
docker compose down  
docker compose up -d
```

The 40-minute limit includes image loading and environment startup. Raise your hand immediately if Docker reports an infrastructure error before either page opens.

Credentials

Role	Student ID	Loan Portal login	Student Chat login
Attacker	9900001	meherun.nesa / nesa-99	meherun.nesa / chat-Meherun-99
Victim	9900002	shafayet.islam / islam-99	shafayet.islam / chat-Shafayet-99

Tasks and Marks

The core assignment is worth 10 marks. One bonus mark is available.

1. **SQL injection confirmation (1 mark):** Demonstrate that the Loan Portal login can be made to authenticate without knowing a correct password.
2. **Schema discovery (2 marks):** Enumerate the relevant application tables and columns and identify how a student's loan amount is stored.
3. **Complete loan-amount extraction (2 marks):** Extract every student's ID, name, and current loan amount through the vulnerable login form.
4. **Persistent browser payload (1 mark):** Use a stacked statement through the login input to persist a stored-XSS payload in the attacker's own Loan Portal record.
5. **Loan App to Student Chat compromise (2 marks):** With the attacker logged in to Student Chat, a normal Loan Portal login must automatically create a Student Chat post containing a convincing reward link, with no separate manual post.
6. **Reward-link CSRF (2 marks):** With the victim logged in to the Loan Portal, clicking the reward link posted in Student Chat must increase the victim's loan amount by exactly \$1000, driven only by the victim's own authenticated session.
7. **Bonus - cover your tracks (+1):** Discover the forensic trail left by Loan Portal login submissions and, through the same injection channel, delete only the trail attributable to the attacker account. Evidence belonging to every other student must remain intact.

Restrictions

- All injection, extraction, persistent modification, and cleanup used for grading must be issued through the Loan Management Portal login form while acting as the attacker account, **9900001**. Direct database edits do not earn marks.
- The victim credentials are supplied only so you can confirm the final CSRF from the victim's point of view. Logging in as the victim to read their loan amount is not extraction, and submitting the victim's student ID directly to any endpoint does not earn CSRF credit.
- Do not attack anything outside the supplied local environment.
- Do not disrupt another student's workstation or containers.

Submission

Create a plain-text file named with your seven-digit student ID, for example 2105XXX.txt. For every graded stage, include:

1. the exact value or payload submitted;
2. the application, field, and account where it was submitted;
3. the observed result and all extracted loan amounts; and
4. the ordered steps needed to reproduce the final loan-amount increase.

Submit only this text file through Moodle. Payloads without their input location or without enough context to reproduce the attack may not receive credit.